# 信息安全测评与风险评估

8.4 风险计算（矩阵法/相乘法）

授课教师：张玉



# 目录

CONTENTS


01 案例导入——“被‘算’低的风险”

02 学习目标

03 风险计算的核心公式（15分钟）

04 风险计算的两种常用方法

# 案例导入——“被‘算’低的风险”

## 核心问题：

有了资产、威胁、脆弱性，如何计算“风险有多大”？算出来的数字，由谁保证它是诚实的？

## 案例回放

2018年10月与2019年3月，波音737 MAX接连坠毁（狮航、埃航），346人遇难——评估矩阵里一路绿灯，天空里两声巨响。

## 案例：波音737 MAX——被“算”低的风险

| 对比项 | 波音的“风险计算” | 事故调查揭示的现实 |
| --- | --- | --- |
| 故障概率 | 把MCAS故障概率假设得极低 | 单一传感器故障即可触发失控 |
| 安全前提 | 假设飞行员数秒内识别纠正 | 飞行员未被告知，无从对抗 |
| 缓解措施 | 省去模拟机培训，缓解项高估 | 机组与系统对抗不及，坠机 |
| 评估结论 | 矩阵里一路绿灯：无需返工 | 346人遇难，机型全球停飞 |
| 教训 | 参数可以讨论 | 结论不能预设 |

# 学习目标

**通过本课学习，你将能够：**

- **理解**风险计算的核心原理（风险 = 资产价值 × 威胁可能性 × 脆弱性严重程度）
- **掌握**矩阵法的计算步骤和等级判定方法
- **掌握**相乘法的计算步骤和等级判定方法
- **能够**运用两种方法对给定场景进行风险计算
- **能够**正确解读风险计算结果并提出处置建议

# 风险计算的核心公式（15分钟）

风险是由三个要素共同决定的：资产价值、威胁可能性、脆弱性严重程度。



# 风险计算的两种常用方法

| 方法 | 特点 | 适用场景 | 优缺点 |
| --- | --- | --- | --- |
| **矩阵法** | 通过查表确定风险等级 | 定性或半定量分析 | ✅直观易懂<br>⚠精度相对较低 |
| **相乘法** | 通过公式计算风险值 | 定量分析 | ✅精度高、可量化 |

**教学要点：**两种方法都是GB/T 20984推荐的方法，实际工作中可结合使用——先用矩阵法快速定性，再用相乘法精确定量。本课重点掌握矩阵法。

# 矩阵法原理与5×5风险矩阵

**矩阵法：将两个要素的值在二维矩阵中进行交叉比对，确定结果值。**

基本原理：**风险 = f(安全事件发生可能性，安全事件损失)**

分别对“可能性”和“损失”赋值（1-5级），在矩阵中交叉定位风险等级。

| 可能性\损失 | 1（很低） | 2（低） | 3（中等） | 4（高） | 5（很高） |
|---|---|---|---|---|---|
| 5（很高） | 高 | 高 | 很高 | 很高 | 很高 |
| 4（高） | 中 | 高 | 高 | 很高 | 很高 |
| 3（中等） | 中 | 中 | 高 | 高 | 很高 |
| 2（低） | 低 | 中 | 中 | 高 | 高 |
| 1（很低） | 低 | 低 | 中 | 中 | 高 |

# 矩阵法计算——分步详解

## 第一步：确定发生可能性

| 威胁频率 | 脆弱性 | 可能性 |
| --- | --- | --- |
| 5 | 5 | 5（很高） |
| 4 | 4 | 4（高） |
| 3 | 3 | 3（中） |
| … | … | … |

→

## 第二步：确定损失等级

| 资产价值 | 脆弱性 | 损失 |
| --- | --- | --- |
| 5 | 5 | 5（很高） |
| 4 | 4 | 4（高） |
| 3 | 3 | 3（中） |
| … | … | … |

→

## 第三步：确定最终风险等级

| 可能性 | 损失 | 风险等级 |
| --- | --- | --- |
| 高 | 高 | **很高** |
| 低 | 高 | 中等 |
| … | … | … |
| | | |

# 矩阵法计算——完整示例

**场景** 某医院核心数据库（资产A），面临“SQL注入攻击”（威胁T），存在“未修复SQL注入漏洞”（脆弱性V）。

**已知条件：**

- 资产价值 =5（极高：涉及患者敏感数据，泄露后果严重）
- 威胁发生频率 =4（高：互联网业务系统面临持续攻击）
- 脆弱性严重程度 =4（高：存在公开利用代码）

**第一步**

**计算安全事件发生可能性**

威胁频率(4) + 脆弱性(4)

→ 发生可能性 = 4(高)

**第二步**

**计算安全事件损失**

资产价值(5) + 脆弱性(4)

→ 损失 = 4(高)

**第三步**

**查风险矩阵确定风险等级**

可能性(4) × 损失(4)

→ 风险等级 = 很高

**结论： 该风险属于“很高”等级，需立即处置。**

# 相乘法原理与计算公式

**相乘法：**直接使用两个要素值进行相乘得到另一个要素的值。

**计算公式（GB/T 20984推荐）：**

$$\text{安全事件发生可能性} = \sqrt{(\text{威胁发生频率} \times \text{脆弱性严重程度})}$$

$$\text{安全事件损失} = \sqrt{(\text{资产价值} \times \text{脆弱性严重程度})}$$

$$\text{风险值} = \sqrt{(\text{安全事件发生可能性} \times \text{安全事件损失})}$$

**简化公式（直接计算）：**

$$\text{风险值} = \sqrt{(\text{资产价值} \times \text{威胁发生频率} \times \text{脆弱性严重程度} \times \text{脆弱性严重程度})}$$

说明： 实际应用中，常用简化公式直接计算风险值，然后对照风险等级划分表确定风险等级。